AI Grid: enterprise AI security strategy

Final synthesis | 28 September 2026

Year 1: October 2026-September 2027. **Three-year horizon:** October 2026-September 2029. **Team:** 2-4 people. **Starting point:** customer demos, pursuing the first customer. Months move together if the start date changes.

1. The strategic decision

Build AI Grid into an AI exposure and assurance product: reconcile what an enterprise has approved with what supported systems reveal, identify material security gaps, route corrective work, and produce evidence that the gaps were addressed.

Start with one cloud AI environment, one security approval/remediation workflow, and 5-8 defensible controls. Over three years, extend into trustworthy agent activity, selected policy-engine integrations, and continuous assurance across a small number of qualified systems.

The first customer promise should be: **"For the AI estate we connect, know what is deployed, who is accountable, what differs from the approved scope, and what evidence supports the next security decision."** Actual use, misuse, prevention, or containment must only be claimed where the corresponding evidence or qualified enforcement exists.

The bank's strongest pain signal is slow, repetitive approval work. Its architecture already assigns roles to registries, identity, gateways, observability, and governance. The industry research adds competitive urgency and useful integration choices. Together, they support a focused security evidence product; they do not justify building every security layer with a 2-4-person team. [B, pp. 18-21, 49; I, pp. 6-13]

Horizon	Product outcome	Commercial evidence sought
Year 1: prove trust and value	Supported inventory reconciles to declared intent; validated findings lead to fresh verification and reusable evidence.	One paid production customer; second independent paid pilot or deployment using the same offer.
Year 2: prove activity and decision context	Correlate selected agent actions to identities, approvals, and outcomes; qualify one downstream policy integration only if justified.	Renewal or expansion; a buyer pays for the added runtime outcome.
Year 3: prove continuous assurance	Reassess material changes across selected sources and reuse portable evidence in recurring reviews.	Retained customers, repeatable delivery, and operating economics that support expansion.

The recommended sequence is: productize existing capability -> win a bounded paid customer -> repeat the same value -> qualify runtime evidence -> selectively integrate control.

This document supersedes the earlier strategy for planning purposes. It combines the two supplied PDFs, the prior proposed version, the inspected working tree, and selected primary public sources. All roadmap targets and Definitions of Done (DoDs) below are proposed acceptance criteria, not achieved results, bank commitments, or revenue forecasts. Customer geography, budget, production configuration, and willingness to pay remain unconfirmed.

Deliverables: this strategy, its PDF edition, and a CSV backlog with 29 roadmap items. Items are sequenced options with dependencies; the tables explicitly distinguish the core commitment from capacity- or funding-dependent work.

2. What the sources change

The bank document describes institutional intent and dated plans, not verified current implementation. The industry report explicitly says its author could not read the bank strategy or the implementation documents. Its product-baseline statements therefore do not override the code review. Page references use PDF page numbers. [B, pp. 46-49; I, pp. 2, 5, 28]

Evidence	Implication for AI Grid	Roadmap response
Repeated questions and approval delays [B, p. 49]	Sell less preparation and rework around a concrete security decision.	Y1-01, 06, 07, 09
Enterprise AI map, grey AI, registry synchronization [B, pp. 11-13]	Keep a normalized observed inventory linked to customer-owned declarations.	Y1-03, 04; Y2-06
Approved purpose, data sensitivity, residency, entity and scope [B, pp. 15-16]	Import authoritative intent; show conflicts rather than silently overwrite it.	Y1-04, 05, 10
User, agent and tool identity; least privilege [B, pp. 29-32]	Assess configuration first; qualify delegation and action evidence later.	Y1-05; Y2-01, 02, 03
Redaction before telemetry distribution [B, pp. 34-36]	Default to minimized metadata, approved destinations and explicit provenance.	Y1-02; Y2-01
Bank retains institutional policies and risk appetite [B, pp. 7-9]	Customer risk owners approve intent, exceptions and release decisions.	Y1-04, 06; Y2-02
Model security and lineage are planned needs [B, p. 46]	Capture component context now; integrate specialist results when paid demand exists.	Y1-10, 13; Y3-02
Cross-platform discovery is competitive [I, pp. 9-10]	Prove incremental decisions and effort savings against the buyer's existing tools.	Y1-01, 07, 09
Broad discovery, runtime and deployment options [I, pp. 15-26]	Select a narrow supported boundary; expand only after qualification and funding.	All expansion gates

Retain from the industry research: relationship-based exposure analysis, integration with existing security systems, enterprise onboarding discipline, and an independent evidence view across selected platforms.

Revise from that research and the earlier proposed version: universal discovery claims; a mock-only or Azure-disabled baseline; mandatory product separation before selling; arbitrary scale targets; simultaneous SaaS, repository, cloud and endpoint discovery; multiple hosting modes; and assumed 10-14, 25-30 or 40-55-person staffing. A booked penetration test is not production acceptance. Certification issuance and regulator acceptance are external outcomes, not engineering completion criteria.

The bank's February-April 2026 planning increment and 2026-2027 tool-selection milestones are discovery prompts for a buyer conversation. They are not evidence of an open procurement or a purchase deadline today. [B, pp. 46-48]

3. Competitive position and first customer

Gartner forecasts spending on securing AI to rise from about $2.835 billion in 2026 to $4.783 billion in 2027. This is a market forecast, not AI Grid's addressable market or a sales forecast. Consolidation and expanding platforms make a narrow, provable advantage more valuable than a broad feature list. [W1]

Competitive alternative	Evidence and overlap	AI Grid response
Cloud-native AI and identity tools	Existing provider APIs and Microsoft agent identities address parts of inventory, identity and access. [W5]	Use authoritative provider evidence; show the unresolved discrepancy or review task.
AI security specialists	Noma and Zenity advertise discovery, posture, identity and runtime capabilities. [W3, W4]	Treat neutral discovery as contested. Compare decision quality, integration effort and proof of fixes.
Broad security platforms	Cisco AI Defense and Palo Alto Networks' Protect AI acquisition span discovery, model/application security and runtime protection. [W2, W6]	Integrate their outputs where useful; avoid a breadth race with their gateways and detectors.
Governance and workflow platforms	ServiceNow AI Control Tower advertises cross-system discovery, governance and security. [W7]	Keep customer registry/workflow identifiers; prove additional verified evidence that improves their process.
Manual evidence collection	Customer-specific baseline to establish during qualification.	Win on preparation effort, traceability, correct gaps and verified resolution.

Vendor descriptions establish competitive overlap, not independently tested efficacy. Being an external vendor does not by itself provide organizationally independent second-line assurance. The customer must define reviewer independence, conflicts and approval rights.

Differentiation hypothesis: AI Grid connects approved scope, observed configuration, validated controls, accountable remediation and fresh evidence with less integration and reviewer effort for a specific regulated AI estate. This hypothesis fails if the buyer's existing tools already produce the same accepted decision with comparable effort and cost.

First segment: a reachable banking business unit, smaller regulated institution, or financial-services team with live cloud AI, an imminent security review, a named platform owner, and a budget owner able to purchase a bounded pilot. The attached bank is a reference environment, not an assumed customer.

First offer: a paid six-week security baseline and evidence pilot, starting after access readiness. Scope: one provider, one business unit, 1-3 accounts/subscriptions, 2-5 representative applications where available, one declaration import, 5-8 controls and one workflow destination. Smaller estates can use their complete supported population.

Buying group: security sponsor, AI platform owner, risk/evidence reviewer, access owner and economic buyer. The CISO is not assumed to be every deal's budget owner. Founder-led selling should establish the existing alternative, measurable pain, access feasibility and purchase decision date before substantial custom work.

Pricing hypothesis: paid fixed-scope pilot, optionally credited to an annual base fee plus bounded monitored scope. Price new deployment patterns and material integrations explicitly. Track delivery labor and infrastructure cost. Validate price points with prospects; the supplied sources do not justify a specific ARR forecast.

4. Baseline, architecture and product boundaries

The read-only review found a substantial API-backed application. It did not execute the product, credentials, production deployments or test suites. Implemented code is evidence of a starting point, not proof of enterprise readiness. Existing local application changes were preserved.

Reuse and qualify	Incremental work to prioritize
AWS Bedrock/AgentCore/SageMaker, Azure Foundry/ML/Search and Copilot metadata collection; real inventory APIs [C1-C3]	One provider's exact coverage, permissions, deletion/staleness behavior and customer reconciliation.
Normalized relationships, evidence snapshots, ownership and policy assessment [C2, C4]	Declared-versus-observed reconciliation, field authority, approval context and defensible explanations.
Canonical AI findings, reassessment and ServiceNow path [C5-C6]	Customer-qualified lifecycle, idempotence, exception expiry and verified fixes.
JWT, roles, tenant routing, production safety configuration and root CI [C7-C8, C12]	Customer IdP qualification, negative isolation tests, recovery, independent security review and operating evidence.
Policy validation, versioning and release governance [C9]	Curated control tests, genuine independent reviewers and operational release evidence.
Runtime ingestion, execution records and readiness logic [C10-C11]	Authoritative typed producer evidence. Current provider telemetry does not prove consequential action decisions and outcomes.

Use three linked records: **customer declaration** (what is intended/approved), **observed evidence** (what a source actually reports), and **validated assessment** (what a versioned control can conclude). Each carries source, time, scope, confidence and responsible party. Neither a customer declaration nor an incomplete observation should silently overwrite the other.

Reconciliation states are **matched, observed but undeclared, declared but unobserved, and conflicting/drifted**. A missing resource can reflect permissions or collection failure; it is not automatically deletion. Control outcomes retain **pass, fail, unknown and not assessed**, with nonapplicability justified separately. Probabilistic runtime signals do not silently clear deterministic posture findings; fresh, relevant verification can resolve them.

Build and own	Integrate or reuse	Defer unless separately funded
Evidence model; discrepancy logic; validated controls; exposure explanations; fix verification; portable evidence	Customer registries/CMDB; IdP; cloud APIs; ITSM; scanner/DSPM results; gateway events; one policy engine	Native gateway; endpoint agent fleet; model hosting/training; broad red teaming; full model-risk governance; universal inline blocking

The observed evidence inventory remains an AI Grid capability. Business purpose, risk appetite and approval authority remain customer-owned. Reuse the existing canonical finding/workflow model without forcing AI risks into CVE semantics. Avoid a separate service rewrite or product extraction unless demonstrated customer isolation, packaging or scaling requirements require it.

Snapshot hashes establish useful integrity checks; they do not independently make storage immutable. Configured access is not observed misuse. Metadata collection is not prompt inspection or token validation. An inventory graph is useful only when it improves a decision or a fix.

5. Capacity and commitments

Two people: technical founder/product and one primary engineer, with fixed-scope external security review. Run one engineering workstream. **Three people:** add integration/quality capacity. **Four people:** founder/product plus backend/integration, product/full-stack and platform/security capability; roles may overlap.

Reserve 35-40% of engineering time for testing, security fixes, operations, integration failures and support. Sales and procurement also consume founder time. For initial planning, assume roughly **30-35 net engineer-weeks at two people**, **55-60 at three**, and **75-85 at four**, depending on founder engineering availability. These are planning envelopes, not hiring or delivery facts.

The Year-1 core is estimated at **22-39 incremental engineer-weeks**, excluding founder-led sales, access waiting, independent review and certification work. This range must be replaced by a bottom-up estimate by day 30. At two-person capacity the upper range does not fit: narrow workflow depth, defer convenience automation, or move dates. Never compress security or evidence gates to make the calendar appear feasible.

Capacity	Year 1	Year 2	Year 3
2 people	Y1-01 through 12 with minimal import/export and one provider; date flexibility if estimate exceeds capacity.	Core retention/operations plus one trusted runtime source and reviewer workflow. Risk-feed/release-gate work is export-only or deferred.	Continuous evidence plus either provenance export or one complementary source; defer federation, private hosting and automated response.
3 people	Core; use added capacity for reliability and repeat onboarding first.	Same core; select one funded integration after telemetry qualifies.	One expansion at a time; no new support model without capacity.
4 people	Core plus at most one of model-result integration or a runtime experiment in Q4.	Trusted runtime, autonomy review and one policy/release integration; choose one expansion, not every option.	Continuous assurance plus at most two sequential expansions meeting demand and support gates.

Funded expansion scenario: 6-8 people can support distinct core, integration and platform/operations responsibilities, but a broader roadmap must be re-estimated. A 10-14-person scenario can justify more parallel discovery and deployment work only with funded demand. The industry report's larger staffing trajectory is not the base plan.

Deployment gate in month 1: agree whether approved-region SaaS is acceptable. If a customer requires a private collector, price and qualify Y1-15 as a substitution for other work. If it requires a fully customer-hosted control plane or air gap before purchase, evaluate a separately funded deployment engagement now or select another first buyer. A Year-3 roadmap entry cannot satisfy a current procurement prerequisite.

Every new connector, control surface or hosting pattern must have a buyer, evidence contract, validation budget and support owner. Conditional items cannot be added cumulatively to the core plan merely because they appear in this document.

6. One-year and three-year roadmap at a glance

Calendar interpretation: the main phase table is the 3-4-person target; M6 production is most credible at four people. At two people, plan M1-3 for buyer/security setup, M4-6 for dependable evidence and controls, M7-9 for production qualification/conversion, and M10-12 for repeat onboarding. The detailed windows below reflect this distinction. First-customer dates remain contingent on access, review and procurement.

Phase	Priority roadmap items	Exit evidence
Q1 / M1-3 / Oct-Dec 2026	Y1-01 buyer/pilot; 02 secure boundary; 03 dependable collection; begin 04 reconciliation and 05 controls	Paid pilot; approved data boundary; usable supported inventory and reviewable control evidence.
Q2 / M4-6 / Jan-Mar 2027	Complete 04-05; 06 remediation; 07 evidence; 08 operating gate; 09 conversion	Accepted security workflow; completed production gate; first paid production target.
Q3 / M7-9 / Apr-Jun 2027	10 approval drift/context; 11 repeat onboarding; operational improvement	Same offer sold to a second independent customer; reduced bespoke delivery.
Q4 / M10-12 / Jul-Sep 2027	12 reliability/economics and renewal readiness; optionally 13 OR 14	Stable core, paid repeat demand, scoped decision on next investment.
Year 2 / M13-24 / Oct 2027-Sep 2028	Y2-01 trusted actions; 02 autonomy review; conditional 03 policy feed / 04 release gate; select 05 OR 06; 07 retention	Paid runtime value within its qualified boundary; renewal/expansion and sustainable support.
Year 3 / M25-36 / Oct 2028-Sep 2029	Y3-03 continuous assurance and 07 retention; select from 01 federation, 02 provenance, 04 RAG boundary, 05 private deployment, 06 response	Repeated accepted assurance; retained customers; selective expansion justified by evidence and economics.

Y1-15 is a month-1 deployment branch, not an extra Q4 feature. Year-2 and Year-3 entries show an ordered opportunity set, not a promise to deliver every item with two people.

Priority notation: P0 = trust/release prerequisite; P1 = core customer outcome; P2 = conditional expansion. **Roles:** F = founder/product; E = engineering lead; C = authorized customer reviewer/owner; X = independent external specialist. The delivery owner prepares evidence; the named approver accepts it. A two-person vendor must budget independent reviewers where existing high/critical release rules require them.

Effort: estimates are active incremental engineer-weeks, not elapsed duration. Work reuses existing implementation. Customer access, procurement, independent review, legal assessment and support can extend dates. Overlapping month windows express dependencies and customer waiting, not an instruction to run many engineering streams.

Universal DoD: each item needs versioned acceptance evidence, documented supported scope and limitations, an owner, relevant negative/failure tests, operational instructions where applicable, and customer acceptance when it changes the customer's workflow. Engineering completion, product qualification and commercial outcomes are tracked separately.

The detailed item pages below supply scope, dependency, owner, effort, evidence and measurable DoDs. The CSV carries the same 29 IDs for import into a planning tool.

7. Year 1 detailed backlog: qualify the first outcome

Y1-01 | Contract one valuable security decision

Window: M1, then monthly commercial review. **Priority:** P1 core. **Owner:** F; C accepts pilot criteria. **Effort:** 0.5-1 engineer-week plus founder effort. **Dependencies:** current demo pipeline.

Scope: Interview 6-8 relevant prospects. Select one repeated approval or remediation problem, one provider and the existing alternative. Produce a capability matrix: implemented, qualified, preview and unsupported. Agree deployment and data handling before promising dates.

Definition of Done

1. A charter names budget owner, sponsor, platform/access owner and risk reviewer.
2. It fixes supported resources, 5-8 candidate controls, baseline effort, acceptance sample, data boundary, price and decision date.
3. A specimen evidence pack shows the additional decision/evidence AI Grid provides beyond existing tools.
4. A signed paid pilot/PO is recorded separately as the commercial gate; interview completion is not a sale.

Acceptance evidence: signed charter or documented rejection reasons, baseline worksheet and capability matrix. **Boundary:** no commitment to enterprise-wide discovery or a bank-wide rollout. **Basis:** B p. 49; I pp. 12-14.

Y1-02 | Qualify one secure customer environment

Window: M1-3; two people M1-4. **Priority:** P0 core. **Owner:** E; C approves boundary; X assesses security. **Effort:** 4-6 engineer-weeks. **Dependencies:** Y1-01; Y1-15 if private collection is mandatory.

Scope: Reuse JWT, roles, tenant isolation and deployment configuration. Complete one customer IdP path, read-only permissions, secret handling, support access, deletion/retention and audit events. Choose one supported deployment model.

Definition of Done

1. Customer approves data flow, region, retention, subprocessors and access scopes.
2. Production-profile authentication, forbidden-role, cross-tenant negative tests, session/revocation behavior and audited privileged access pass.
3. Raw prompts, responses, credentials and tool arguments are excluded from the initial collection boundary and tested with seeded sensitive data.
4. Demo data and auto-approval are off; synthetic approvals cannot satisfy release gates.
5. Before sensitive customer data enters the pilot, a basic backup/restore and incident-response path is exercised; independent review of that boundary is complete with critical/high findings remediated. Full production qualification follows Y1-08.

Acceptance evidence: configuration manifest, IdP/isolation/privacy results, assessment closure and customer approval. **Boundary:** a sanitized evaluation does not qualify production operation. **Basis:** B pp. 34-36, 39-40; C3, C7-C9.

Y1-03 | Make one provider's discovery dependable

Window: M1-3; two people M2-5. **Priority:** P0 core. **Owner:** E; C confirms reference population. **Effort:** 3-5 engineer-weeks. **Dependencies:** Y1-02 access/data boundary.

Scope: Qualify the existing collector for the actual buyer's AWS, Azure or supported Copilot environment. Cover stable IDs, pagination, throttling, retries, permission failures, stale evidence and deletion semantics. Publish supported resource and relationship types.

Definition of Done

1. Inventory finds at least 95% of independently enumerated supported in-scope resources; every discrepancy is explained.
2. Unsupported types and inaccessible scopes appear separately.
3. Fourteen consecutive days meet the agreed daily collection schedule; failures alert and cannot create a pass.
4. A usable baseline arrives within seven business days after access readiness.
5. Customer identifies owners for every designated critical AI system, or the ownership gap is explicitly open.

Acceptance evidence: reference export, reconciliation report, 14-day health record and permission/error tests. **Boundary:** resource discovery is not proof of use; no all-cloud parity claim. **Basis:** B pp. 11-13; C1-C3.

Y1-04 | Reconcile declared intent with observed assets

Window: M2-4; two people M4-6. **Priority:** P1 core. **Owner:** E; C owns declaration authority. **Effort:** 2-3 engineer-weeks. **Dependencies:** Y1-03 and a customer declaration sample.

Scope: Add one CSV or narrow API import from the bank's registry/CMDB. Store customer IDs and field authority for owner, purpose, environment, provider, region, allowed legal entity/permitted data scope where applicable, classification, approver and approval expiry. Preserve a normalized AI Grid evidence inventory.

Definition of Done

1. Seeded matched, observed-undeclared, declared-unobserved and conflicting/drifted cases produce correct, reviewable states.
2. Stable keys, duplicate handling and manual match decisions are auditable; ambiguous records are not silently merged.
3. Every imported/observed field retains source and timestamp.
4. Stale imports or collector failure cannot erase assets or imply decommissioning.
5. Customer reviewer accepts discrepancies and assigns resolution owners.

Acceptance evidence: versioned sample import, matching contract, seeded-case results and discrepancy sign-off. **Boundary:** two-person implementation is import/export; bidirectional registry ownership and synchronization are deferred. **Basis:** B pp. 11-16; I pp. 8, 13.

Y1-05 | Release a small, validated control pack

Window: M2-4; two people M4-7. **Priority:** P0 core. **Owner:** E; independent policy reviewers and C approve. **Effort:** 2-4 engineer-weeks. **Dependencies:** Y1-03; Y1-04 for declaration-dependent controls.

Scope: Select 5-8 evidence-supported controls spanning ownership/registration, approved location/provider, service identity, excessive tool/data reach, logging freshness or unsupported guardrail configuration. Identity and approved-scope checks belong to this pack, not another parallel product.

Definition of Done

1. Every control has source fields, applicability, severity, rationale and positive, benign, absent, stale and permission-denied cases.
2. Pass/fail/unknown/not-assessed behave correctly; reachability and observed misuse remain distinct.
3. Production release passes current digest-bound validation, bias and approval gates, including the configured 95% Wilson lower-bound precision requirement at 95% confidence and two independent reviewers for high/critical policies.
4. Three customer-agreed scenarios and one fresh verified fix are demonstrated.
5. Unsupported runtime/token-verification claims are removed.

Acceptance evidence: versioned answer keys, holdout results, release digest, approvals and reviewed customer cases. **Boundary:** pilot precision metrics do not replace stronger release gates. **Basis:** B pp. 29-32; C4, C9.

Y1-06 | Connect a finding to accountable, verified resolution

Window: M3-5; two people M6-8. **Priority:** P1 core. **Owner:** E; C owns treatment. **Effort:** 2-3 engineer-weeks. **Dependencies:** Y1-05.

Scope: Reuse canonical AI findings and the existing ServiceNow path if relevant; otherwise use export or one small destination adapter. Implement ownership, severity, due dates, expiring exceptions, reopening and fresh reassessment.

Definition of Done

1. Create/retry/reconcile is idempotent; repeated scans do not duplicate work.
2. Each ticket links to the exact evidence and policy version.
3. Open, accepted-risk, expired-exception, verified-resolved and reopened cases pass.
4. Two customer-owned cases complete the intended lifecycle, using sanctioned exercises if needed.
5. Ticket closure, policy disabling and risk acceptance are never reported as a verified fix.

Acceptance evidence: linked lifecycle histories, retry/failure cases and fresh post-fix snapshots. **Boundary:** one workflow destination; no new ticketing platform or uncontrolled auto-remediation. **Basis:** B p. 21; C5-C6.

Y1-07 | Produce evidence a reviewer can reuse

Window: M4-6; two people M7-9. **Priority:** P1 core. **Owner:** E and F; C accepts evidence. **Effort:** 2-3 engineer-weeks. **Dependencies:** Y1-04 through 06.

Scope: Create a compact application/control evidence pack and machine-readable export, with customer IDs, scope, result, source, timestamp, control version, exceptions and disposition. Map only relevant framework/control references with versions.

Definition of Done

1. Every released pilot control is traceable from conclusion to evidence.
2. Export totals reconcile to the UI; missing and unsupported evidence stays visible.
3. Retention, deletion and legal-hold cases follow the agreed policy.
4. Two comparable reviews show a target of at least 50% less active preparation effort than the recorded manual baseline, with required evidence complete.
5. Reviewer signs acceptance or records specific gaps; a missed value target triggers workflow revision, not a claim of success.

Acceptance evidence: accepted packs, baseline/time logs, completeness checks and export validation. **Boundary:** framework mapping is not certification; preparation time is measured separately from overall approval lead time. **Basis:** B pp. 21, 49; I pp. 12-13.

Y1-08 | Pass the production operating gate

Window: M4-6; two people M7-9. **Priority:** P0 core. **Owner:** E; X tests security; C accepts operations. **Effort:** 3-5 engineer-weeks. **Dependencies:** Y1-02 through 07.

Scope: Establish monitored service health, backup/restore, upgrade/rollback, support ownership, incident response and capacity limits. Exercise tenant-aware restoration and prevent restored data from crossing retention or access boundaries.

Definition of Done

1. Witnessed isolated restore meets agreed targets, initially proposed RPO 24 hours/RTO 8 hours.
2. Thirty days meet the proposed 99.5% availability SLO with transparent downtime accounting.
3. At twice the contracted pilot load, queues recover after transient failures and key UI reads meet the agreed target, initially p95 <=2 seconds.
4. Independent production-scope security findings have no unresolved critical/high issues.
5. Upgrade/rollback and an incident exercise succeed; support hours and escalation are accepted.

Acceptance evidence: restore and load reports, SLO history, test closure, incident record and operating pack. **Boundary:** stricter customer requirements need funded scope; no implied 24/7 global coverage. **Basis:** I pp. 17-19; C7-C8, C12.

Y1-09 | Convert the pilot into paid production

Window: M4-6; two people M7-9, gated by procurement. **Priority:** P1 core commercial milestone. **Owner:** F; customer budget owner decides. **Effort:** 0-0.5 engineer-week plus founder effort. **Dependencies:** Y1-07 and 08.

Scope: Run a joint readout covering incremental value, accepted evidence, verified treatment, deployment/support scope and annual commercial terms. Document unresolved procurement prerequisites and owners.

Definition of Done

1. Security sponsor and reviewer accept the contracted product outcome.
2. Production admission passes Y1-08 and the shared release gate.
3. A paid production agreement or PO is executed; an evaluation extension is labeled as such.
4. The next review, operational owner and renewal/expansion decision are scheduled.
5. If no purchase follows, record product, budget, timing or procurement reason and make an explicit continue/change/stop decision.

Acceptance evidence: signed acceptance, contract/PO, mutual action plan and dated readout. **Boundary:** this is a target dependent on a buyer, not something engineering can guarantee by month 6. **Basis:** B p. 49; I pp. 13, 19.

Y1-10 | Detect drift from approved scope

Window: M7-9; two people M9-11. **Priority:** P1 core. **Owner:** E; C owns approval rules. **Effort:** 1-2 engineer-weeks. **Dependencies:** Y1-04, 05 and 07.

Scope: Reassess changes to owner, approved provider/region, material tool permission and component/model version. Store supplier, version, digest when available, approval and expiry, clearly labeled observed, imported, attested or unknown.

Definition of Done

1. Each agreed material-change case reopens the correct control/review task.
2. Expired or revoked approval is visible and cannot remain an unconditional pass.
3. Two application reviews reuse the same scope template.
4. The customer records final approval; green posture alone cannot approve a use case.
5. Model identity/version gaps remain visible rather than filled with inferred provenance.

Acceptance evidence: change-case results, approval histories and version/source records. **Boundary:** basic component context is not a model scanner, behavioral safety assessment or full autonomy certification. **Basis:** B pp. 15-16, 21, 46.

Y1-11 | Repeat onboarding for a second independent customer

Window: M7-10; two people M10-12. **Priority:** P1 core. **Owner:** F and E; second C accepts. **Effort:** 1.5-3 engineer-weeks plus sales. **Dependencies:** Y1-09 and stable support load.

Scope: Sell the same security decision, preferably on the same provider. Reuse installation, permission, validation and evidence templates. Keep customer differences in configuration.

Definition of Done

1. A second independent customer signs a paid pilot or production agreement.
2. Usable baseline arrives within seven business days after access readiness.
3. Core installation consumes <=5 engineering days, excluding customer waiting, without an application fork.
4. Bespoke work is <=20% of pilot delivery effort, or the overrun produces a repeatability fix before the next sale.
5. Acceptance reuses the same core control/evidence contracts.

Acceptance evidence: paid agreement, onboarding time log, change/configuration record and customer acceptance. **Boundary:** another business unit in the first bank is expansion, not independent repeatability evidence. **Basis:** I pp. 13, 22-23.

Y1-12 | Prove reliability, support economics and next demand

Window: M10-12, then ongoing. **Priority:** P1 core. **Owner:** F and E. **Effort:** 1-3 engineer-weeks. **Dependencies:** operating customer data; Y1-11 where available.

Scope: Publish a customer scorecard for source coverage/freshness, unknown evidence, reviewed precision, verified fixes, preparation effort, service health and direct costs. Select next-year scope based on renewal and paid demand.

Definition of Done

1. The last 60 days meet agreed collection/support targets or have accepted corrective plans.
2. Direct hosting, integration, support and founder delivery labor are recorded per customer.
3. Renewal or continuation intent and budget process are documented; actual renewal is recorded separately when due.
4. The same added capability is requested by two buyers, with at least one funding a pilot, before expansion is approved.
5. The board/founders choose one next investment and explicitly defer the rest.

Acceptance evidence: scorecard, cost ledger, renewal notes and signed investment decision. **Boundary:** customer counts and gross-margin goals are planning indicators, not fabricated traction. **Basis:** I pp. 23, 27-28.

8. Year 1 conditional branches

Y1-13 | Integrate specialist model-security results

Window: M10-12 at four-person capacity; otherwise Year 2+. **Priority:** P2 conditional. **Owner:** E; C approves scope. **Effort:** 3-6 engineer-weeks. **Dependencies:** Y1-10, stable core and a funded model-security problem.

Scope: Import an existing scanner/evaluation report first. If a scanner invocation is necessary, support one artifact store and one format in a bounded execution environment. Attach source, tool version, artifact digest, scan scope and expiry to the application/component.

Definition of Done

1. Supported benign and unsafe fixtures produce the expected labeled results; report the sample and known blind spots.
2. Unsupported format, encrypted/missing artifact, timeout and malformed-model cases remain unknown or failed scans.
3. Resource limits and untrusted-artifact handling pass security review.
4. A changed digest invalidates the matching prior result.
5. Two customer release/review decisions use the result.

Acceptance evidence: result schema, fixture report, isolation tests and accepted review records. **Boundary:** ModelScan addresses particular unsafe serialization/code patterns; a clean scan or valid signature does not establish behavioral safety, fairness or training-data integrity. Choose this OR Y1-14. **Basis:** B p. 46; I pp. 20-23; W8-W9.

Y1-14 | Prove one typed runtime evidence contract

Window: M10-12 experiment at four-person capacity; otherwise Y2-01. **Priority:** P2 conditional. **Owner:** E; customer producer owner validates. **Effort:** 4-6 engineer-weeks. **Dependencies:** Y1-02, 05 and stable core.

Scope: Integrate one trusted customer agent/gateway producer for actor, agent/version, action/tool, decision, approval reference and outcome. Test privacy and correlation before developing behavioral detections or enforcement.

Definition of Done

1. The contract defines authoritative versus informational fields and provenance.
2. A 14-day pilot includes >=100 real customer executions and >=50 real consequential actions, with >=95% useful decision/approval/outcome completeness over those actions. Synthetic tests are separate and cannot satisfy operational qualification.
3. Agent correlation is >=90%; version correlation is >=80% over at least 50 version-applicable records.
4. Replay, duplicates, clock skew, revocation and redaction tests pass.
5. A reviewer can reconstruct ten sampled actions, with gaps visible.

Acceptance evidence: schema, labeled source corpus, completeness/correlation report and reviewed timelines. **Boundary:** this experiment does not pass the existing multi-provider Program 2 gate or authorize production runtime policies. Choose this OR Y1-13. **Basis:** B pp. 29-36; C10-C11.

Y1-15 | Qualify private collection when the first buyer requires it

Window: decision M1; delivery re-estimated before contract. **Priority:** P2 conditional commercial prerequisite. **Owner:** F and E; customer platform/security approve. **Effort:** 4-8+ engineer-weeks. **Dependencies:** explicit deployment requirement and funded capacity.

Scope: Package one customer-controlled collector with an approved metadata egress contract to the agreed control plane. Choose one customer environment and install method. Separate collection location from control-plane hosting and full air-gap operation.

Definition of Done

1. Customer accepts what leaves the environment, destination, encryption, credentials and retention.
2. Installation, least-privilege permissions, upgrade/rollback, network outage and secret rotation pass.
3. Logs and egress tests show no unapproved content transfer.
4. A second clean installation follows the same package/runbook.
5. Funding, support ownership and displaced roadmap items are signed off before production commitment.

Acceptance evidence: approved architecture, deployment manifest, egress/privacy tests and two installation records. **Boundary:** this does not provide a privately hosted UI/database/control plane or air gap. If those are purchase prerequisites, qualify a separate funded scope or choose a different first customer. **Basis:** B pp. 8, 39-40; I pp. 22-23.

9. Year 2 strategy: trustworthy activity before control

Year 2 should answer a narrower question than "is every agent safe?": **Can the enterprise reconstruct a supported consequential action, establish who/what authorized it, and compare it with approved scope?** This follows the bank's identity, delegated-access and telemetry architecture. [B, pp. 29-36]

The two-person path is Y2-01, a minimal Y2-02 reviewer workflow, and Y2-07 operations/retention. Where runtime evidence is unavailable, remain a strong posture/evidence product and sell validated value; do not convert missing signals into confident behavior claims.

At four people, add one qualified policy-feed or release-evidence integration after source qualification. Select Y2-05 response integration or Y2-06 complementary discovery only if core support capacity remains. An existing customer-controlled identity or gateway boundary usually offers a better integration point than building an AI Grid gateway.

Native cloud logs, OTEL transport and API availability are not equivalent to trusted policy decisions. The current runtime readiness implementation requires multiple qualified provider sources for its existing release program. A single custom adapter needs an explicitly separate, reviewed qualification program; it cannot silently weaken that gate. [C10-C11]

10. Year 2 detailed backlog

Y2-01 | Qualify attributable agent action evidence

Window: M13-16. **Priority:** P1 conditional on runtime demand. **Owner:** E; customer producer owner and policy reviewers approve. **Effort:** 5-8 engineer-weeks, less only if Y1-14 is accepted. **Dependencies:** Y1-12 investment gate and trusted producer access.

Scope: Productize one actor/agent/tool/action timeline with delegation references, decision, approval, outcome, event identity and provenance. Record whether each link is asserted, observed or independently validated. Retain metadata minimization.

Definition of Done

1. The source passes a versioned qualification contract and Y1-14 quality floors.
2. Authenticated producer identity, signing/transport trust as applicable, replay rejection and schema/version handling are tested.
3. A sampled action chain is reconstructible without treating natural-language explanation as authorization proof.
4. Missing events and untrusted fields cannot yield a pass.
5. Production release follows either the unchanged existing multi-source program or a separately approved adapter program with explicit scope and independent review.

Acceptance evidence: producer certification, labeled event corpus, privacy tests and release-program decision. **Boundary:** no universal action attribution; no raw chain-of-thought collection. **Basis:** B pp. 29-36; C10-C11; W5.

Y2-02 | Assess readiness for a specified autonomy level

Window: M15-18. **Priority:** P1 once runtime scope qualifies. **Owner:** E and F; C defines/approves autonomy profile. **Effort:** 2-4 engineer-weeks. **Dependencies:** Y1-10, Y2-01.

Scope: Represent a customer-owned action profile: allowed tools/data, material-action approval, least privilege, transaction limits where applicable, human escalation, stop mechanism and evidence freshness. Support an assessment and approval workflow.

Definition of Done

1. Each required condition maps to observed configuration, validated runtime evidence or an explicit manual attestation.
2. Missing evidence prevents an unconditional readiness conclusion.
3. The customer's sanctioned execution boundary produces valid allowed, denied, approval-required and emergency-stop evidence in controlled tests; AI Grid assesses that evidence.
4. Two application reviews produce named, expiring customer decisions.
5. A material scope/version change reopens the review.

Acceptance evidence: versioned profile, linked tests, approved reviews and stop-exercise record. **Boundary:** readiness for one agreed scope is not general agent safety certification. AI Grid does not own the customer's risk appetite or automatically grant autonomy. **Basis:** B pp. 15-16, 21, 29-32.

Y2-03 | Supply trustworthy risk attributes to one policy engine

Window: M17-20. **Priority:** P2; four-person or funded integration. **Owner:** E; customer policy/enforcement owner approves. **Effort:** 4-6 engineer-weeks. **Dependencies:** Y2-01, 02 and a paid policy decision use case.

Scope: Export narrowly defined, signed or equivalently authenticated attributes to one OPA, Cedar or existing customer policy service. Include asset identity, state, evidence/control version, issued-at and expiry. Begin in shadow mode.

Definition of Done

1. Trust keys/identities, audience, replay protection, revocation and expiry are tested.
2. Consumer behavior for stale/missing/conflicting values is explicitly approved and tested; fallback is chosen per risk, not universally fail-open or fail-closed.
3. Shadow decisions match a reviewed answer key.
4. Policy owner accepts bounded production promotion and rollback after a failure exercise.
5. Each decision is traceable to the exported attribute and source evidence.

Acceptance evidence: contract, security tests, shadow comparison and signed consumer acceptance. **Boundary:** a read-only producer still influences enforcement indirectly; AI Grid must qualify that influence. No general policy engine or inline gateway. **Basis:** B pp. 18-21, 29-32.

Y2-04 | Attach security evidence to an AI release decision

Window: M18-21. **Priority:** P2; export-only at two people. **Owner:** E; customer release owner approves. **Effort:** 2-4 engineer-weeks. **Dependencies:** Y1-07, 10; Y1-13 if scanner evidence is required.

Scope: Produce a machine-readable evidence manifest for one application's release/version with control outcomes, component references, exceptions and validity. Integrate one CI/release workflow only when paid demand requires it.

Definition of Done

1. Evidence binds to a stable application/component version or digest; changed inputs invalidate relevant results.
2. For export-only scope, the customer reviewer/consumer correctly interprets allowed, disallowed and expired cases. For an authorized blocking integration, a benign release proceeds and a disallowed/expired test release is held.
3. Missing or stale evidence follows the customer's explicit decision policy.
4. Emergency exception, expiry and rollback are auditable.
5. Two real release reviews use the artifact; blocking remains separately authorized.

Acceptance evidence: manifests, version-change tests, release histories and owner acceptance. **Boundary:** export completion is distinct from enforcement qualification. A signature proves origin/integrity, not model safety. **Basis:** B pp. 21, 46; W8.

Y2-05 | Integrate one bounded partner response

Window: M20-23. **Priority:** P2 funded option; choose versus Y2-06. **Owner:** E; customer incident/enforcement owner authorizes. **Effort:** 4-7 engineer-weeks. **Dependencies:** Y2-01 and 03; release/support gates.

Scope: Use an existing gateway, identity or tool-control system for one response, such as temporarily disabling a specific tool permission or route. Start with recommendation and explicit operator approval.

Definition of Done

1. Detection/evidence, target identity and proposed action are unambiguous.
2. Customer authorizes the action boundary and permissions.
3. Dry-run, approval, execution result, idempotence, timeout and rollback cases pass.
4. A sanctioned containment exercise verifies effect using fresh evidence from the enforcement system.
5. Source outage and incorrect targeting do not cause an unapproved broad action.

Acceptance evidence: action contract, authorization, exercise and rollback records. **Boundary:** no unattended general remediation or all-provider kill switch. Irreversible credential revocation needs approved credential-reissuance recovery and is outside the reversible automation track. Advisory output remains advisory until independently qualified. **Basis:** B p. 21; I pp. 24-26.

Y2-06 | Add one complementary discovery source

Window: M20-23. **Priority:** P2 paid-demand option; choose versus Y2-05. **Owner:** E; C accepts reference scope. **Effort:** 4-7 engineer-weeks. **Dependencies:** repeat onboarding and support capacity.

Scope: Select one second cloud, repository inventory, enterprise SaaS or existing SSE/CASB/identity usage feed. Choose the source that closes the most valuable demonstrated blind spot. Avoid building an endpoint/browser fleet.

Definition of Done

1. Two buyers request the same source and one funds qualification.
2. The adapter documents resource/event semantics, permissions, freshness and blind spots.
3. Supported inventory reconciliation is >=95% against an independent reference; event feeds use an agreed labeled sampling method instead of an invented asset denominator.
4. Duplicate/conflicting identities remain reviewable.
5. A seeded unregistered case and a known approved case are correctly distinguished.

Acceptance evidence: demand records, connector contract, comparison corpus and customer acceptance. **Boundary:** cloud resources, repository mentions and employee use are different evidence types, never interchangeable proof of deployed AI. **Basis:** B pp. 11-13; I pp. 6-10, 20-21.

Y2-07 | Earn renewal and operationally support the new scope

Window: M13-24, with quarterly gates. **Priority:** P0/P1 core. **Owner:** F and E; C accepts service scope. **Effort:** 3-5 engineer-weeks of planned improvement, plus reserved operations. **Dependencies:** installed base and any accepted expansion.

Scope: Version support contracts, review policy quality, monitor telemetry costs and publish customer scorecards. Prepare only the assurance/certification work actual buyers require, with an independent auditor where needed.

Definition of Done

1. At least one renewal or paid expansion occurs when contract timing permits; earlier intent is labeled as intent.
2. Every supported source has an owner, failure alert, upgrade policy and cost limit.
3. Three consecutive monthly reviews meet agreed support/quality targets or pause expansion until corrected.
4. External audit readiness evidence is complete for the purchased scope; auditor issuance is tracked separately.
5. Direct contribution margin and capacity are acceptable under a founder-approved business case that includes support labor.

Acceptance evidence: renewal/expansion record, operating scorecards, cost model and scoped audit evidence. **Boundary:** no automatic promise of SOC 2, ISO certification, 24/7 support, or 10-15 customers. **Basis:** I pp. 23-25, 27-28.

11. Year 3 strategy: continuous assurance within a qualified boundary

Year 3 should make periodic evidence a continuously maintained capability: supported material changes refresh the relevant assessment, reopen review when necessary, and preserve a portable decision history. The customer should be able to see what is current, what is unknown, and what action remains.

At two people, prioritize Y3-03 and Y3-07, plus a minimal provenance export or one complementary evidence source. At four people, add at most two sequential, funded expansions. Federation, RAG/memory testing, private control-plane operation and automatic response are distinct engineering and support commitments; they are not one feature bundle.

The long-term advantage to pursue is dependable decision evidence across selected products, supported by a growing body of validated controls and repeatable qualification. Integration breadth alone is easy for larger competitors to claim. Trust is earned through correct outcomes, explicit limitations, low operating effort and renewals.

Expansion to another regulated vertical requires evidence that the same product, control contracts and delivery process work there. Bank-specific adapters and control profiles should remain configuration/extensions around a common model.

12. Year 3 detailed backlog

Y3-01 | Trace selected cross-agent and cross-system relationships

Window: M25-29. **Priority:** P2; four-person/funded option. **Owner:** E; customer platform owners validate. **Effort:** 5-8 engineer-weeks. **Dependencies:** two qualified sources and Y2-01.

Scope: Link one customer workflow across selected agents, identities, tools and systems, including a supported A2A interaction only if used by the customer. Distinguish configured connectivity, observed invocation and verified delegation.

Definition of Done

1. Every reported edge carries source, timestamp, relationship meaning and confidence.
2. Five agreed change/exposure scenarios identify the correct affected applications and unresolved gaps.
3. Unobserved delegation or unsupported protocols remain unknown.
4. A customer reviewer reconstructs the supported workflow from exportable evidence.
5. A sanctioned failure/cascade exercise shows the limits of available visibility.

Acceptance evidence: relationship schema, scenario corpus, reconstructed workflow and exercise report. **Boundary:** no universal cross-agent trust graph or guaranteed cascade detection. Pin protocol versions; requalification follows material changes. **Basis:** B pp. 18-21, 29-32; I pp. 24-26.

Y3-02 | Make component provenance and evaluation portable

Window: M26-30. **Priority:** P2; minimal export possible at two people. **Owner:** E; C accepts evidence usage. **Effort:** 3-5 engineer-weeks. **Dependencies:** Y1-10; specialist-result inputs if sold.

Scope: Export a supported CycloneDX ML-BOM or equivalent documented component manifest with model/provider/version, known dependencies, provenance references, evaluation scope and approval validity. Import one specialist result if Y1-13 was deferred and paid demand exists.

Definition of Done

1. Export validates against the selected schema/version.
2. Known, attested and unknown provenance fields remain distinct.
3. Version/digest changes invalidate applicable results.
4. A customer tool consumes the export and a reviewer reproduces two release/evaluation decisions.
5. Supplier claims and scanner findings retain their original scope and source.

Acceptance evidence: schema validation, round-trip consumer test and reviewed decisions. **Boundary:** a BOM records composition/provenance claims; it does not prove model trustworthiness. Full training lineage may remain unavailable. **Basis:** B p. 46; I pp. 22-23; W8-W9.

Y3-03 | Maintain continuous, reviewer-accepted assurance

Window: M27-33. **Priority:** P1 core within supported scope. **Owner:** E; C accepts recurring evidence. **Effort:** 3-5 engineer-weeks. **Dependencies:** Y1-07, 10 and qualified change sources.

Scope: Refresh affected controls after relevant changes, maintain evidence validity and publish current assurance by application/control. Reuse event notifications where trustworthy and scheduled reconciliation where necessary.

Definition of Done

1. A 90-day evaluation achieves >=95% fresh evidence across applicable contracted control instances; stale/unknown/unavailable instances count as misses.
2. Every agreed material-change test triggers the correct reassessment or review task within the contracted refresh interval.
3. Two successive periodic packs are accepted by customer reviewers.
4. Ten sampled applications, or the full smaller population, have traceable chains for contracted controls with gaps disclosed.
5. Risk acceptance remains separate from verified remediation.

Acceptance evidence: 90-day denominator-based report, change tests, accepted packs and portable histories. **Boundary:** measure assurance coverage for the contracted scope, not total organizational safety or legal compliance. **Basis:** B p. 21; I p. 26.

Y3-04 | Evaluate one RAG or memory trust boundary

Window: M29-33. **Priority:** P2 research/pilot only until qualified. **Owner:** E with specialist partner; C authorizes data/tests. **Effort:** 5-8+ engineer-weeks. **Dependencies:** funded repeated demand, approved content access and test environment.

Scope: Select one retrieval/memory workflow and a precise failure, such as cross-user retrieval or unauthorized memory writes. Prefer customer/specialist evaluation results to building broad poisoning detection. Define expected permissions and observed behavior.

Definition of Done

1. Data access, seeded tests and sensitive-content handling are approved.
2. A labeled benign/adversarial corpus measures the selected failure with reported sample size and limitations.
3. Source attribution, expected authorization and observed retrieval/write are linked.
4. The agreed fix is verified on fresh tests without suppressing benign use.
5. Independent review decides whether to productize, keep as a service, or stop.

Acceptance evidence: approved protocol, evaluation results, privacy review and go/no-go decision. **Boundary:** metadata alone cannot prove content-level poisoning detection; no blanket RAG safety claim. **Basis:** I pp. 24-26; W10-W11.

Y3-05 | Qualify one fully customer-controlled deployment

Window: M29-34; earlier only as separately funded prerequisite. **Priority:** P2 separate investment. **Owner:** E plus funded operations owner/partner; C approves. **Effort:** 8-12+ engineer-weeks. **Dependencies:** contracted demand and full lifecycle support budget.

Scope: Choose one private control-plane hosting pattern, with UI/API/database, secrets, observability, storage and upgrades. An air-gapped variant requires a distinct offline installation, update and licensing/support design; it is not assumed included.

Definition of Done

1. Customer validates network/egress, residency, keys and administrative access.
2. Two clean installations, one upgrade/rollback and a witnessed restore pass.
3. Vulnerability patching, backups, telemetry access and support responsibilities are contractually assigned.
4. Evidence export and retention/deletion behave correctly.
5. Customer or funded partner covers the required operational hours and accepts the support model.

Acceptance evidence: deployment qualification, tested runbooks, network verification and signed responsibility matrix. **Boundary:** private collector, private control plane and air gap remain separately named products/scopes. **Basis:** B pp. 39-40; I pp. 22-23.

Y3-06 | Permit a narrowly authorized reversible response

Window: M31-35. **Priority:** P2; four-person/funded option. **Owner:** E; customer incident/risk owners authorize. **Effort:** 4-7 engineer-weeks. **Dependencies:** Y2-05, strong source quality and independent safety/security review.

Scope: Promote one previously qualified response from operator approval to a preauthorized rule for a narrow target class and condition. Preserve manual override, dry run, rate limits, audit and rollback.

Definition of Done

1. Customer signs the exact trigger/action/target boundary and expiry.
2. Evidence spoofing, stale state, incorrect identity, repeated events and outage tests cannot cause an out-of-scope action.
3. Effect and rollback are verified in a sanctioned exercise at contracted load.
4. A canary period meets agreed false-action and recovery criteria before broader use.
5. Revocation disables automation within a customer-agreed, measured maximum propagation time; cached-policy and disconnected-consumer behavior pass the agreed tests.

Acceptance evidence: authorization, independent review, canary record, action/rollback proof and revocation test. **Boundary:** no autonomous general-purpose remediation or guarantee of a universal response time. **Basis:** B p. 21; I p. 26.

Y3-07 | Demonstrate a durable, repeatable business

Window: M25-36, quarterly review. **Priority:** P1 core. **Owner:** F with E for support economics. **Effort:** 2-4 engineer-weeks of planned productization, plus commercial work. **Dependencies:** accepted core and customer cohort.

Scope: Improve renewals, repeat deployment, support and partner delivery. Validate another segment only after the core offer repeats. Price expanded evidence sources and operating obligations explicitly.

Definition of Done

1. At least two renewal/paid-expansion decisions succeed across the installed base when due.
2. Three consecutive monthly reviews meet approved contribution-margin and support-capacity thresholds.
3. Repeat onboarding uses the supported package without customer code forks.
4. Any delivery partner completes an accepted deployment using documented boundaries and escalation.
5. The next strategic plan is grounded in retention, paid demand and operating evidence, not connector count.

Acceptance evidence: customer cohort/renewal records, cost/support ledger, deployment records and next investment decision. **Boundary:** capacity-based planning targets are three retained paid production customers at two people or five at four; these are hypotheses to revisit quarterly, not forecasts or maximum market potential. **Basis:** I pp. 26-28.

13. Shared production and policy release gate

No calendar milestone overrides these requirements. Evidence for production admission must include:

1. **Security boundary:** tested customer IdP/roles/revocation, cross-tenant isolation, read-only collection where intended, secret handling and audited support access. Independent production-scope assessment completed; no unresolved critical/high findings.
2. **Privacy and provenance:** approved data flow/retention, minimization tests, source identity/timestamps, clear attested versus observed fields, and correct stale/missing states. No silent content collection expansion.
3. **Policy quality:** versioned/digest-bound answer keys and holdouts, bias review and required independent approvals. Current defaults require a 95% Wilson lower-bound precision threshold at 95% confidence; high/critical policies require two independent reviewers. Small pilot samples or a 90% operating metric do not satisfy that gate. [C9]
4. **Operations:** passing restore, upgrade/rollback, incident and contracted-load exercises; measured service health; staffed support scope; supported version and vulnerability remediation process.
5. **Customer acceptance:** supported coverage, limitations, workflow, risk treatment and purchased deployment model accepted by authorized owners. Legal applicability and procurement conditions are resolved for that purchase.

The current runtime Program 2 gate requires at least two required provider-connector sources, and every required provider-connector source must pass its rolling 14-day volume/completeness/correlation checks. Reviewed defaults include >=100 executions per source, >=95% populated approval/policy/action-outcome fields over consequential events, >=90% agent correlation and >=80% version correlation with >=50 version-applicable records. These existing field-population checks do not prove semantic validity or authority; proposed producer qualification adds those requirements. Custom adapters do not count as substitutes under that existing gate. A separate adapter qualification program requires an explicit reviewed design and release decision. [C11]

14. Measurement and pilot acceptance

The primary product outcome is **current, reviewer-accepted security evidence and verified treatment of material gaps in the contracted AI estate**. A single risk score or growing asset count does not establish it.

Measure	Definition and initial proposed target	Interpretation
Supported inventory coverage	Discovered independently enumerated supported resources / all such in-scope resources; >=95%	Show reference method, timestamp, exclusions and every discrepancy.
Evidence freshness	Applicable contracted control instances with evidence within agreed validity / all applicable contracted instances; >=95% for continuous assurance	Unknown, stale and unavailable count as misses. Show justified nonapplicable and exceptions separately.
First usable value	<=7 business days from access readiness to accepted baseline	Also record signature-to-access delay, which is a different process.
Reviewed alert precision	Confirmed valid findings / adjudicated alert sample; pilot operating target >=90%	Publish sampling method, count, severity and uncertainty. Production policy gate remains stronger.
Supported scenario sensitivity	Detected agreed violations / seeded supported holdout violations; target >=90%	Publish corpus; this is not universal attack recall.
Verified treatment	Count/rate of findings resolved by fresh, relevant evidence	Risk acceptance and ticket closure reported separately.
Reviewer effort	Active evidence preparation/rework hours versus comparable baseline; target >=50% reduction in two reviews	Overall approval lead time and customer waiting reported separately.
Reliability and recovery	Initially propose 99.5% availability, RPO 24h/RTO 8h for the observation product	Contract stricter requirements only with capacity and tested architecture.
Business quality	Paid conversion, independent repeat sale, renewal, delivery days, support hours and direct contribution margin	Include founder delivery labor; avoid vanity ARR/customer targets.

Six-week pilot after access readiness: weeks 1-2 establish supported inventory, declarations and quality; weeks 3-4 review controls and remediate agreed cases; weeks 5-6 deliver evidence, compare effort and hold the purchase readout. Security admission work can precede that clock. Schedule the customer reviewers and commercial decision before starting.

Acceptance requires an agreed reference population, 14-day collection evidence, three control scenarios, one fresh verified remediation, a reviewer-accepted pack, and an explicit comparison with the existing alternative. Use sanctioned fixtures if genuine violations are absent. A missed metric produces a documented remediation or stop decision, not an edited denominator.

Standards approach: maintain versioned mappings to customer-selected requirements and authoritative NIST/OWASP references. Pin technical protocol versions and review material updates. Framework coverage is a navigation aid, not proof of compliance. Customer-specific EU AI Act or other legal applicability must be confirmed for the use case, role and jurisdiction; do not base the commercial plan on an assumed regulatory deadline. [W10-W12]

15. Decisions, risks and the next 90 days

Trigger	Decision/action
No paid commitment after 6-8 qualified conversations or by M3	Revisit problem, buyer, access and price. Continue necessary trust work; stop adjacent expansion.
Existing tools already solve the decision with similar effort	Narrow the unresolved gap or disqualify the opportunity; discovery breadth alone is insufficient differentiation.
Evidence cannot support a proposed control	Relabel as unknown/not assessed, remove the claim, or qualify another source. Do not infer token validation or enforcement from metadata.
Security, privacy, precision or recovery gate fails	Hold the dependent release; remediate and retest.
Mandatory private hosting/certification/support exceeds capacity	Obtain exact scope and funded delivery/audit plan before commitment, or choose a more suitable buyer.
Support consumes the reserved budget for two months	Pause new sources, remove the dominant support cause, adjust scope/price or fund capacity.
Model or runtime track has no paid buyer	Continue posture/evidence improvements; keep the expansion in research.
Policy feed or response affects a customer decision	Treat the trust, expiry, fallback and rollback contract as a product obligation even if AI Grid has no write credentials.

Window	Action and concrete output	Owner
Days 1-10	Review demo pipeline; conduct focused interviews; choose one provider/problem. Record existing alternatives, capability truth and required deployment.	F + E
Days 11-20	Produce pilot charter, sample evidence pack, approved data-flow design and source reference population. Size incremental work and independent review.	F + E + C
Days 21-30	Close paid pilot/access plan; validate the 22-39 engineer-week estimate against actual team capacity. Cut or redate scope if it does not fit.	F + E
Days 31-60	Qualify secure environment and collector; import declarations; validate initial control cases and error/unknown behavior.	E + X + C
Days 61-90	At 3-4 people, complete the quality window and first evidence review; at two, qualify the collection baseline and schedule the remaining controls/review. Set the conversion plan.	F + E + C

The first 90 days are successful when a buyer is funding a concrete security decision, the connected evidence is trustworthy within its stated boundary, and the customer can explain why the outcome is better than its existing process. The first year makes that repeatable. The following two years expand only the evidence and control surfaces customers will pay to operate reliably.

16. Sources and evidence notes

B - Bank strategy: user-supplied *AI in Bank.pdf*, 49 pages, /Users/gowrikarthik.gadela/Downloads/AI in Bank.pdf. Text and relevant architecture, maturity, roadmap and blocker images reviewed. Main references: pp. 7-9 institutional ownership; 11-17 inventory/approved context; 18-21 architecture/maturity; 29-36 identity/telemetry; 39-40 sovereignty; 46-48 planned roadmap; 49 adoption blockers. Its plans were not independently verified as deployed.

I - Industry research: user-supplied *AI Industry Research.pdf*, 28 image-based pages, /Users/gowrikarthik.gadela/Downloads/AI Industry Research.pdf. All pages visually reviewed across the review team. Main references: pp. 1-4 thesis/market/standards; 5 baseline assumptions; 6-13 problems/competition/buyers; 14 staffing; 15-23 Year 1; 24-26 Years 2-3; 27-28 risks/limitations. Its author discloses lack of access to the bank and implementation documents. Unverified breach statistics, acquisition valuations, protocol-version claims and legal claims were not used as planning facts.

The user's earlier proposed synthesis was reviewed as a proposal, not as an instruction source: /Users/gowrikarthik.gadela/.codex/attachments/1ce286cc-41e2-45da-bd88-b2c2cf3809ed/Pasted text.txt. The explicit 2-4-person team constraint takes precedence over its larger staffing assumptions.

C - Implementation evidence: read-only static review of the supplied working tree, including existing local modifications. No production access, application execution or test-suite run was performed for this strategy. These references show code/documentation evidence, not certified operation. Paths below are under /Users/gowrikarthik.gadela/Desktop/AI Projects/NoScan/.

- **C1:** prototype-app/frontend/src/pages/AiInventoryPage.tsx:112 - API-backed inventory.
- **C2:** prototype-app/docs/business-logic-guide.md:330 - pipeline/governance; runtime discussion around lines 425 and 478. Documentation is corroborating context, not stronger evidence than service logic.
- **C3:** prototype-app/backend/src/main/java/com/prototype/vulnwatch/aisecurity/service/AiSecurityMetadataSanitizer.java:14 - metadata privacy boundary.
- **C4:** AiGridSnapshotService.java:68 and AiGridAssessmentService.java:145 in the same service directory - snapshots and assessment uncertainty.
- **C5:** AiGridFindingService.java:54 in that directory - canonical findings/reassessment.
- **C6:** prototype-app/backend/src/main/java/com/prototype/vulnwatch/aisecurity/controller/AiGridFindingIncidentController.java:31 - incident integration.
- **C7:** prototype-app/backend/src/main/java/com/prototype/vulnwatch/config/JwtDecoderConfig.java:20 - JWT configuration.
- **C8:** TenantAwareDataSource.java:87 in that config directory and prototype-app/backend/src/main/resources/application-prod.yml:32 - isolation/production setup.
- **C9:** AiGridValidationGovernanceService.java:293 and :439, and AiGridDemoPolicyAutoPublishService.java:19 in the AI security service directory - release gates and demo behavior.
- **C10:** prototype-app/backend/src/main/java/com/prototype/vulnwatch/aisecurity/azure/AzureFoundryRuntimeCollectionService.java:51 and aisecurity/copilot/CopilotStudioRuntimeCollectionService.java:44 - runtime evidence limitations.
- **C11:** AiGridRuntimeTelemetryReadinessService.java:234 in the AI security service directory - provider-source readiness rules.
- **C12:** .github/workflows/quality.yml:11 and .github/workflows/performance-governance.yml:44 - existing CI. A stale README claim that CI is absent should not drive rebuilding it.

17. Primary public references

Public facts were checked on 27-28 September 2026. Vendor pages are evidence of advertised scope, not independent efficacy validation. Confidential bank contents were not submitted in web searches.

- **W1:** Gartner forecast: securing AI market, 26 August 2026. Forecast totals and competitive context; not AI Grid TAM.
- **W2:** Palo Alto Networks completes Protect AI acquisition, 22 July 2025. Evidence of platform investment and advertised product scope.
- **W3:** Noma AI asset discovery. Advertised cross-platform discovery and connected risk capabilities.
- **W4:** Zenity product overview. Advertised agent discovery, posture and runtime security.
- **W5:** Microsoft Entra agent identities and administrative management. Agent identities are specialized service principals; avoid a simplistic agent-versus-service-principal dichotomy.
- **W6:** Cisco AI Defense data sheet. Advertised discovery, testing and runtime capabilities.
- **W7:** ServiceNow expands AI Control Tower, 5 May 2026. Governance/workflow platforms also compete across discovery and security.
- **W8:** CycloneDX ML-BOM. Component/provenance representation; not a safety guarantee.
- **W9:** Protect AI ModelScan. Supported serialization scanning scope and limitations.
- **W10:** NIST AI Risk Management Framework and Generative AI Profile, AI 600-1. Risk-management reference, not automatic compliance.
- **W11:** OWASP GenAI LLM Top 10 2026. Versioned threat reference.
- **W12:** European Commission: AI Omnibus enters into force. Updated regulatory timing is a reason to verify applicability and dates for each customer rather than inherit deadline claims from a market report.

Evidence discipline: Bank needs are source-derived. Product status is static-review evidence. Public market and vendor claims are attributed above. Positioning, sequencing, staffing, numerical acceptance targets and commercial gates are recommendations from this synthesis and require customer validation. No certification, legal compliance, detection efficacy, customer win or production readiness is claimed as already achieved.